

HO CHI MINH UNIVERSITY OF SCIENCE

FACULTY OF INFORMATION TECHNOLOGY

DATA SECURITY IN INFORMATION SYSTEMS



THEORY REPORT
CHAPTER 8: MALWARE

LECTURER:

Phạm Thị Bạch Huệ - Lương Văn Minh

STUDENT (GROUP 7):

Đỗ Quang Minh Triết - 23127131

Đinh Đại Vũ - 23127144

Lê Phạm Kiều Duyên - 23127184

Lê Trương Bảo Ngọc - 23127237

Nguyễn Đăng Phôn - 23127451

Contents

1	Introduction and Scope of Research	6
2	Classification and Architecture of Malicious Software	7
3	Vulnerabilities and Malware Enablers	8
4	Attack Vectors	9
5	Anatomy of an Attack	10
6	Case Study: The MGM Resorts Cyberattack (September 2023)	11
6.1	Background and Context	11
6.2	The Two Threat Actors	11
6.3	Phase 1 — Reconnaissance and Probing	12
6.3.1	The Intelligence Gathering	12
6.3.2	Why This Phase Is the Most Critical	12
6.4	Access and Privilege Escalation	12
6.4.1	The Entry Point: Okta	12
6.4.2	Lateral Movement: From Cloud to Physical Operations	13
6.4.3	Data Exfiltration: The Double-Extortion Setup	13
6.4.4	The Ransomware Deployment	14
6.5	Phase 3 — Covering Traces of the Attack	14
6.5.1	The Backdoor Architecture	14
6.5.2	Escalation Upon Detection: Attacking the Responders	14
6.5.3	Attribution and Legal Aftermath	15
6.6	Impact Analysis	15
6.7	Mapping to the CIA Triad	15
6.8	Defensive Lessons	18
7	Defense strategies and Risk mitigation	20
7.1	Overview of Defense Strategies	20
7.2	Defense-in-Depth Model	20
7.2.1	Concept of Defense-in-Depth	20
7.2.2	Integration of the AAA Access Control Framework	21
7.3	Enhancing Access Control and User Authentication	21
7.3.1	Role of Authentication in Preventing Attacks	21
7.3.2	Weaknesses of Single-Factor Authentication (SFA) and Common At- tack Methods	21
7.3.3	Levels of Upgrading Authentication Strategy	22
7.3.4	Real-world Case Study: Security Transformation at Google	22
7.4	Patch Management Process and Risk Reduction	23
7.4.1	Concept and Importance of Patch Management	23
7.4.2	Standard Patch Management Process	23
7.4.3	Real-world Case Study: WannaCry Ransomware Disaster	23
7.5	Data Backup Strategy and the 3-2-1 Rule	24
7.5.1	Importance of Backup in Security	24

7.5.2	Gold Standard: The 3-2-1 Backup Rule	24
7.5.3	Enhanced Defense: Immutable and Air-gapped Backup	24
7.5.4	Core Benefits and Practical Application	24
7.6	Incident Response Lifecycle	25
7.6.1	Importance of Incident Response	25
7.6.2	Six Phases of the Incident Response Lifecycle	25
7.6.3	Real-world Example (Ransomware Response Scenario)	25
7.7	User Awareness and Security Recommendations	26
7.7.1	Humans: The Weakest Link	26
7.7.2	Common Risky Behaviors	26
7.7.3	Recommendations and Solutions	26
7.8	Future Trends and Conclusion	26
7.8.1	Emerging Cybersecurity Threats	26
7.8.2	Overall Conclusion	27
8	Future Trends in Malicious Software	28
9	Conclusion	29
	References	30

List of Figures

1	Attack surface progression from identity compromise to on-prem operational impact	13
2	Complete attack chain of the MGM Resorts cyberattack (September 2023) .	16
3	Day-by-day response timeline of the MGM incident (Sep 8–19, 2023)	16
4	Security reports indicate that implementing MFA can prevent more than 99% of automated account takeover attacks [1].	22

List of Tables

1	List of group members	5
2	Task distribution and completion status	5
3	Incident impact summary for the MGM Resorts cyberattack	17
4	CIA triad mapping for the MGM Resorts incident	18

Group Members

No.	Full Name	Student ID	Email
1	Đỗ Quang Minh Triết	23127131	dqmtriet23@clc.fitus.edu.vn
2	Đinh Đại Vũ	23127144	ddvu23@clc.fitus.edu.vn
3	Lê Phạm Kiều Duyên	23127184	lpkduyen23@clc.fitus.edu.vn
4	Lê Trương Bảo Ngọc	23127237	ltbngoc23@clc.fitus.edu.vn
5	Nguyễn Đăng Phôn	23127451	ndphon23@clc.fitus.edu.vn

Table 1: List of group members

Task Distribution and Completion Status

No.	Task	Responsible	Student ID	Contribution
1	Defense and Mitigation Strategies	Đỗ Quang Minh Triết	23127131	20%
2		Đinh Đại Vũ	23127144	20%
3		Lê Phạm Kiều Duyên	23127184	20%
4		Lê Trương Bảo Ngọc	23127237	20%
5		Nguyễn Đăng Phôn	23127451	20%

Table 2: Task distribution and completion status

1 Introduction and Scope of Research

2 Classification and Architecture of Malicious Software

3 Vulnerabilities and Malware Enablers

4 Attack Vectors

5 Anatomy of an Attack

6 Case Study: The MGM Resorts Cyberattack (September 2023)

6.1 Background and Context

Threat Actors: Scattered Spider (UNC3944) in coordination with ALPHV/BlackCat ransomware group

Attack Type: Structured, Direct — Social Engineering combined with Ransomware-as-a-Service (RaaS)

Primary Motivation: Financial extortion; later escalated due to what the attackers described as retaliation for failed negotiations

Duration: September 8–19, 2023 — ten days of active disruption

Scale: 29 hotel and resort properties affected worldwide, including Bellagio, MGM Grand, Mandalay Bay, and Cosmopolitan in Las Vegas. Estimated \$100 million loss in third-quarter 2023 revenue. A \$45 million class-action settlement was reached in January 2025.

The MGM Resorts attack is one of the most instructive case studies in modern cybersecurity precisely because of what it did *not* use. There was no zero-day vulnerability, no nation-state malware toolkit, no brute-force password cracking. All the attackers did to compromise a company valued at \$33.9 billion was search LinkedIn, find an employee, and call the help desk. Cyber Security Hub The entire entry into one of the world’s largest hospitality companies cost the attackers approximately ten minutes of conversation.

This case is also notable for its two-actor architecture. Scattered Spider and ALPHV/BlackCat are distinct organizations with complementary capabilities — one specializes in social engineering to obtain access, the other provides professional-grade ransomware infrastructure. Their collaboration represents what the cybersecurity industry now calls a “criminal supply chain,” a division of labor that allows non-technical attackers to cause deeply technical damage.

6.2 The Two Threat Actors

Understanding who executed this attack is essential to understanding how it worked.

Scattered Spider (UNC3944) is a loosely organized group, mostly made up of teenagers and young adults believed to live in the United States and the United Kingdom, believed to be affiliated with the cybercriminal network known as “The Com.” Wikipedia Their defining capability is fluency in English and expertise in social engineering — specifically, the ability to convincingly impersonate employees over the phone to manipulate IT help desk staff. They are not primarily technical hackers; they are manipulators who exploit organizational trust structures.

ALPHV/BlackCat is a professional ransomware-as-a-service operation. BlackCat/ALPHV is a RaaS operation — just as commercial businesses rely on SaaS applications to do their work, criminal gangs rely on RaaS. BlackCat provides the professional services that Scattered Spider lacks. CyberArk The relationship between the two groups follows a division of labor: Scattered Spider gains the access, ALPHV supplies the ransomware and handles extortion operations.

6.3 Phase 1 — Reconnaissance and Probing

6.3.1 The Intelligence Gathering

The reconnaissance phase of the MGM attack required no special tools, no network scanning, and no malware. It required only a LinkedIn account and the knowledge of what to look for.

Scattered Spider used LinkedIn to identify a current MGM Resorts employee, assumed their identity, and called the MGM IT help desk requesting assistance logging into their account. SpecopsSoft From LinkedIn, the attacker gathered the employee’s full name, job title, department, and likely their organizational reporting structure — all publicly available information that any recruiter or sales professional would access routinely. This is what security researchers call Open Source Intelligence (OSINT): the systematic exploitation of publicly available information to build an attack profile.

The target was selected deliberately. Scattered Spider did not pick a random employee — they identified someone whose role and credentials would grant useful access once impersonated. This represents a key insight about modern reconnaissance: the most dangerous intelligence gathering today does not happen on the dark web or through network intrusion. It happens on professional networking platforms that organizations actively encourage employees to use.

6.3.2 Why This Phase Is the Most Critical

Section 5.4.1 of this report identifies reconnaissance as “the most important phase” because everything that follows depends on its quality. The MGM attack demonstrates this in an extreme form. The entire technical complexity of the subsequent attack — the Okta takeover, the Azure Active Directory compromise, the deployment of ransomware across hundreds of servers — was made possible by ten minutes of social engineering built on a LinkedIn search.

The phone call lasted ten minutes, and the attackers were able to gain administrator privileges to MGM’s Okta and Azure tenant environments. University of Hawai’i–West O’ahu No malware was involved in Phase 1. No network was probed. The reconnaissance was entirely human-focused, and its product was the single most valuable thing an attacker can obtain: legitimate administrative credentials willingly handed over by the target organization itself.

6.4 Access and Privilege Escalation

6.4.1 The Entry Point: Okta

Okta is an Identity and Access Management (IAM) platform. Organizations use it as a centralized gateway that controls authentication for all their applications and services — email, cloud infrastructure, internal tools, and more. Gaining administrator access to an organization’s Okta environment is functionally equivalent to obtaining a master key to every door in a building.

This breach provided access to the Okta platform, a crucial access management system. The attackers then capitalized on weak multi-factor authentication to escalate privileges and

gain control of the Azure Active Directory domain controller. Brown & Brown The Azure Active Directory domain controller is the core identity authority for Microsoft-based cloud environments. Controlling it means controlling the ability to create, modify, and impersonate any user account in the organization.

ALPHV publicly confirmed that the affiliate group had achieved persistence in the network and had gained super administrator privileges. Morphisec With super administrator access to both the identity management layer (Okta) and the cloud directory (Azure AD), the attackers had effectively inherited the digital keys to MGM’s entire infrastructure.

6.4.2 Lateral Movement: From Cloud to Physical Operations

What makes this attack particularly instructive is how cloud-based access translated into physical-world disruption. The IdP solution granted highly privileged access to Azure, which ultimately allowed the cloud-originated attack into MGM’s brick-and-mortar operations. CyberArk The identity platform that governed digital logins was configured in a way that allowed the attackers to pivot from the cloud environment into MGM’s on-premises virtualization infrastructure.

The specific mechanism involved credential synchronization between on-premise Active Directory and the cloud. Because MGM synchronized credentials between these environments, gaining control of the cloud identity layer gave Scattered Spider a pathway into the VMware ESXi hypervisor infrastructure — the virtual machine hosts that ran the servers powering MGM’s hotel operations, gaming systems, and booking platforms.

The attack surface progression can be visualized as an identity compromise that propagated through cloud control into on-premises operations:

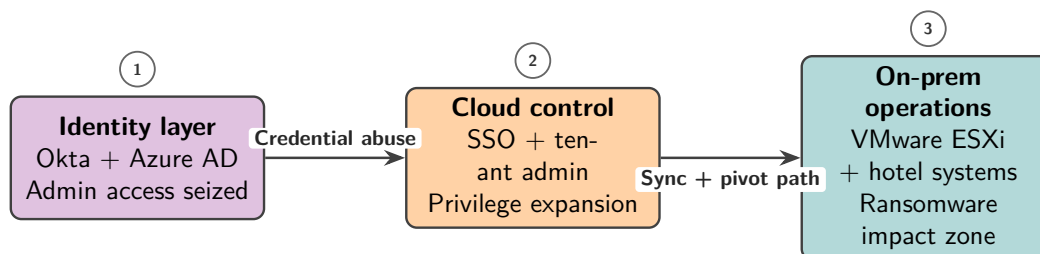


Figure 1: Attack surface progression from identity compromise to on-prem operational impact

6.4.3 Data Exfiltration: The Double-Extortion Setup

Before deploying any ransomware, the attackers ensured they had a second lever of pressure. ALPHV claims to have exfiltrated 6 TB of customer information during this time, upon which they initiated negotiations with MGM to prevent the public release of the stolen data. ALPHV also threatened to disclose the exfiltrated information if an agreement could not be reached. Netwrix

This sequencing is deliberate and important. Data theft before encryption means that even if the victim restores all systems from backup — eliminating the encryption leverage entirely — the attacker retains the ability to cause reputational and regulatory damage through data

publication. This dual-pressure structure is what the industry now calls “double extortion,” and it directly undermines the traditional defense of maintaining strong backups.

6.4.4 The Ransomware Deployment

At this stage, ALPHV/BlackCat took operational control. Using the BlackCat/ALPHV RaaS service, Scattered Spider encrypted several hundred ESXi servers, which hosted thousands of virtual machines supporting hundreds of systems widely used in the hospitality industry. This caused cascading chaos. As the ESXi hosts became encrypted one after another, the applications running on them crashed. CyberArk

The operational consequences were immediate and visible to the public. The effects of the cyberattack on MGM Resorts were immediately apparent: gambling operations were disrupted as slot machines went offline, hotel guests found their digital room keys had stopped working, online reservation and booking systems were shut down, and the MGM mobile app became completely inaccessible. Netwrix Staff reverted to pen and paper to manage guest queues. The attack had successfully converted a digital breach into a physical operational crisis.

6.5 Phase 3 — Covering Traces of the Attack

6.5.1 The Backdoor Architecture

The most forensically significant aspect of Phase 3 is that it began before MGM detected anything. The ransomware was deployed after MGM locked out the network, which means that the attackers had gained significant visibility of the network and had implanted backdoors across the network before the main attack was triggered. Morphisec

This is a critical point that separates sophisticated attackers from unsophisticated ones. By planting backdoors before becoming visible, the attackers ensured that MGM’s detection and response would not equal eviction. Even if MGM successfully expelled the attackers from their primary access route, the pre-planted backdoors would provide re-entry paths. This is the attack equivalent of having multiple escape routes prepared before a heist begins.

6.5.2 Escalation Upon Detection: Attacking the Responders

MGM’s incident response team identified the intrusion the day after initial access was gained — September 9 — when they detected unusual activity and traffic on the company’s systems. Their response was to terminate the Okta Sync servers, which was the most direct way to cut off the attacker’s credential-harvesting operations. This response was tactically correct but strategically insufficient.

ALPHV admitted to sniffing passwords on their Okta servers after the initial access. MGM hastily deactivated their Okta Sync servers and essential infrastructure components to prevent an escalation of the attack, causing the interruption of reservation systems, digital room keys, slot machines, and more. University of Hawai’i–West O’ahu The shutting down of Okta was itself what caused the guest-facing outages — meaning MGM’s defensive action created the public disruption, not the ransomware directly.

In a statement, BlackCat noted that MGM Resorts had not responded through the provided communication channel, indicating a reluctance to negotiate. The hackers highlighted that

MGM’s only response to the breach had been to disconnect each and every one of their Okta Sync servers after discovering the intrusion. Avertium The attackers, still possessing access through their pre-planted backdoors, then deployed the ransomware as an escalation — consistent with their own statement that the ransomware component was partly driven by retaliation for what they perceived as bad-faith negotiation.

6.5.3 Attribution and Legal Aftermath

Despite the attackers’ technical evasion during the operation, the group’s English-speaking, socially-visible profile made eventual attribution feasible. In July 2024, the West Midlands Police with the help of the FBI arrested a 17-year-old juvenile in connection with the MGM cyberattacks. In November 2024, 19-year-old Remington Ogletree was arrested on charges related to his alleged involvement with the group. Wikipedia

The arrests underscore a pattern: sophisticated operational security at the technical level does not compensate for poor personal operational security. Members of Scattered Spider communicated openly on Telegram channels and were identifiable through social media activity, which ultimately provided law enforcement with the leads needed to locate them despite the digital obfuscation during the attack itself.

Here is the complete attack chain from reconnaissance through ransomware deployment:

6.6 Impact Analysis

The operational consequences of the attack were severe and immediate across every dimension of MGM’s business.

Financial losses totaled approximately \$100 million in third-quarter 2023 results, with MGM reporting daily revenue losses of roughly \$8.4 million during the ten-day outage. The company additionally committed \$40 million in new cybersecurity investments following the incident, and agreed to a \$45 million class-action settlement in January 2025 covering affected customers from both the 2019 and 2023 breaches.

Operational disruption was total and publicly visible in a way that most cyberattacks are not. Slot machines displayed error messages. Digital room keys failed. Guests could not check in online, make card payments, or access their MGM loyalty accounts. Staff processed hotel transactions by hand. Airport lounges and concierge services lost access to reservation systems. For a hospitality company whose entire value proposition is seamless guest experience, this was the maximum possible reputational damage.

Regulatory and legal consequences extended beyond the settlement. MGM and Caesars Entertainment — which suffered a parallel attack by Scattered Spider the same week and paid a \$15 million ransom — were both required to file mandatory disclosures to the Securities and Exchange Commission under new cybersecurity incident rules. Moody’s Corporation noted the attack may negatively affect MGM’s credit rating due to the company’s heavy operational reliance on technology systems.

6.7 Mapping to the CIA Triad

This attack methodically violated all three pillars of the CIA Triad introduced in Chapter 1 of this report.

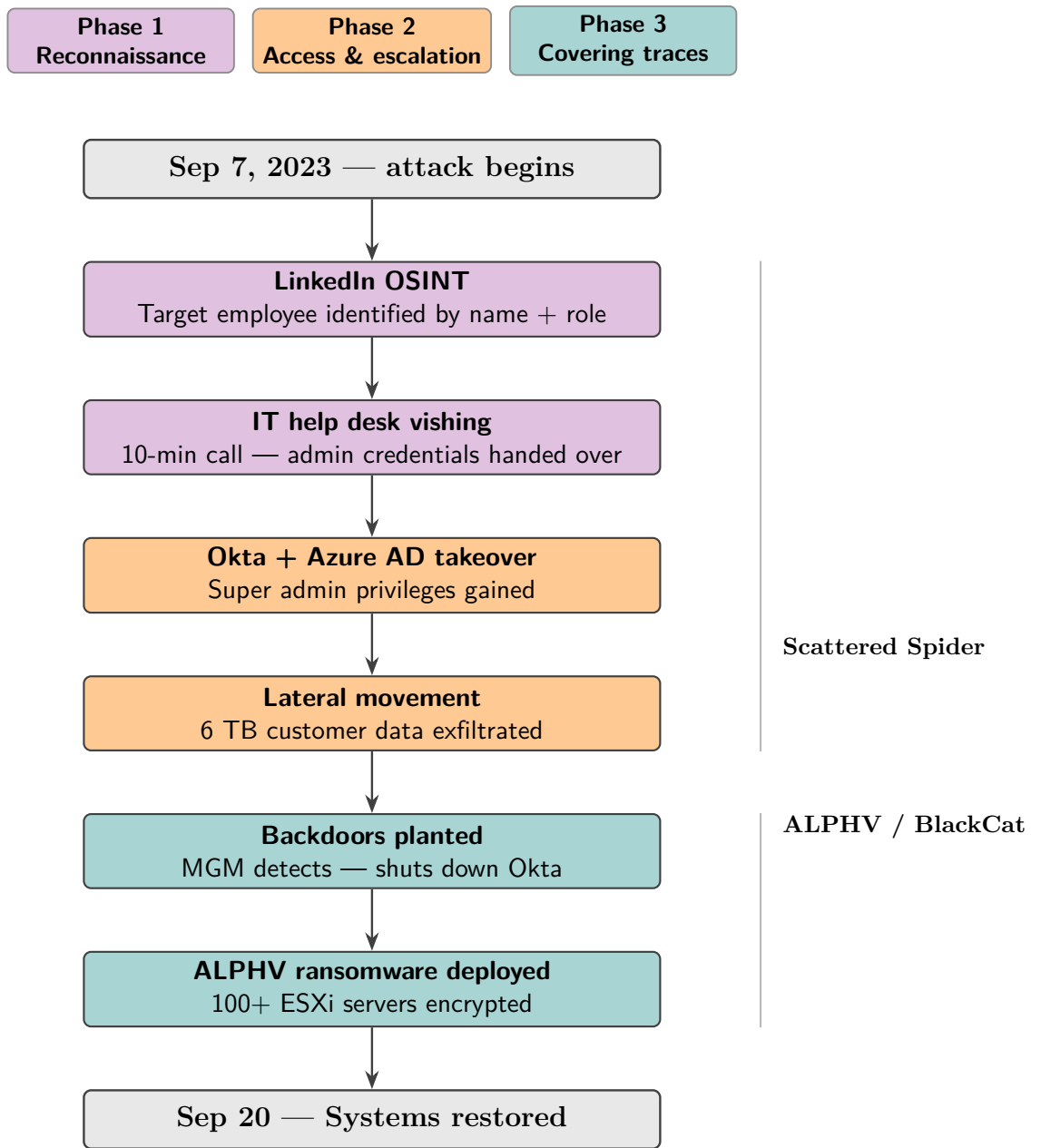


Figure 2: Complete attack chain of the MGM Resorts cyberattack (September 2023)

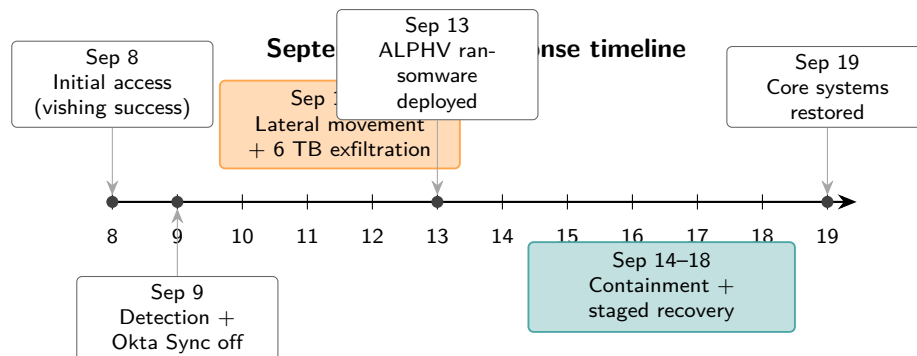


Figure 3: Day-by-day response timeline of the MGM incident (Sep 8–19, 2023)

Impact area	Evidence	Estimated loss	Duration
Financial impact	Q3 2023 revenue reduction and post-incident security spending commitments	\$100M reported outage impact; \$40M additional cybersecurity investment; \$45M class-action settlement	Approx. 10 days of active disruption; legal costs extending into 2025
Operational impact	Slot machines, room keys, booking systems, MGM app, and guest workflows disrupted; staff shifted to manual processing	Daily loss estimated at \$8.4M during outage window	Service degradation across Sep 8–19
Data exposure	Attackers claimed exfiltration of 6 TB of customer data and used leak threats in extortion	No final public total; significant legal and reputational liability exposure	Data theft occurred before encryption phase
Regulatory / legal	SEC incident disclosure obligations and class-action litigation outcomes	\$45M settlement (announced Jan 2025)	Post-incident consequences extending beyond restoration

Table 3: Incident impact summary for the MGM Resorts cyberattack

Confidentiality was breached through the exfiltration of 6 TB of customer data, including personally identifiable information belonging to guests, employees, and vendors. The threat of public data release formed the second half of ALPHV’s double-extortion strategy, maintaining confidentiality pressure even after systems were restored.

Integrity was compromised through the unauthorized modification of MGM’s identity infrastructure. By gaining administrator control of Okta and Azure Active Directory, the attackers could create, alter, and impersonate accounts — corrupting the integrity of the authentication system that the entire organization depended upon.

Availability was the most visibly destroyed pillar. The encryption of over one hundred ESXi hypervisors hosting thousands of virtual machines rendered MGM’s core operational systems — reservations, gaming, payments, room access — completely unavailable for ten days, directly harming guests and generating tens of millions of dollars in lost revenue.

CIA pillar	What was affected	Concrete MGM example
Confidentiality	Sensitive customer and organizational data secrecy	Claimed exfiltration of 6 TB of customer information, followed by threat of public release in extortion pressure
Integrity	Trustworthiness of identity and account-control systems	Unauthorized admin control over Okta and Azure AD enabled account manipulation and impersonation capability
Availability	Continuous access to critical business services	Encryption of 100+ ESXi hosts disrupted reservations, gaming, payments, room access, and mobile services for roughly ten days

Table 4: CIA triad mapping for the MGM Resorts incident

6.8 Defensive Lessons

The MGM attack exposes failures at multiple layers of what Section 7 of this report describes as Defense in Depth. Each layer that should have stopped or slowed the attack either did not exist or was insufficient.

The help desk had no caller verification protocol. The single most important lesson from this attack is that a ten-minute phone call should never produce administrator credentials. Secure service desk practices require callers to authenticate with something they have — a registered device, a hardware token, a one-time code — not only something they know, such as their name and job title. An attacker with LinkedIn access knows everything that knowledge-based verification checks for.

Multi-factor authentication on privileged accounts was weak. The attackers capitalized on weak multi-factor authentication to escalate privileges and gain control of the Azure Active Directory domain controller. Brown & Brown MFA on administrative accounts must be phishing-resistant — hardware security keys or certificate-based authentication — not SMS or app-push approvals, both of which are vulnerable to social engineering.

The network lacked segmentation between identity and operations. The critical failure that converted a digital breach into a physical operational crisis was the pathway from cloud identity management to on-premise ESXi infrastructure. A properly segmented network with strict boundaries between the identity management layer, corporate IT, and operational technology would have contained the blast radius significantly.

Backups did not protect against the double-extortion model. MGM's ability to restore systems after ten days demonstrates that backup capabilities existed. However, restoring data from backup does nothing to address the 6 TB of already-exfiltrated customer records. The triple-extortion model described in Chapter 8 of this report — encryption, data theft, and harassment — renders traditional backup-as-defense incomplete.

User awareness training must explicitly address vishing. The IT help desk staff who granted credentials were not acting maliciously or carelessly by their own training standards — they were following normal helpdesk procedures. User awareness programs must include specific scenarios for voice-based impersonation attacks, with clear protocols that override normal helpfulness instincts when administrative access is at stake.

7 Defense strategies and Risk mitigation

7.1 Overview of Defense Strategies

In the context where malicious software (malware) is increasingly growing in sophistication and evasion capability, relying solely on a single security solution has become outdated and insufficient to withstand threats. Modern organizations are required to implement a “Defense-in-Depth” strategy – establishing a comprehensive multi-layered protection framework to address cybersecurity risks [2].

The core objectives of this defense strategy are built upon three main operational pillars:

- **Prevention (Prevent):** Stop intrusion attempts from outside right at the first barriers.
- **Detection (Detect):** Early and accurate identification of attack signs or abnormal behaviors within the system.
- **Mitigation (Mitigate):** Isolate risks, minimize damage, and quickly restore operations when a security incident occurs.

To realize these three pillars, a complete defense strategy requires the coordinated integration of multiple protection layers. Among them, User Authentication plays the role of a foundational building block and the first line of defense, enabling access control, ensuring traceability, and protecting data integrity.

However, strong authentication is only the starting point. To make the system truly resilient against all attack scenarios, organizations must combine authentication with other risk management pillars, including: continuously reducing vulnerabilities through Patch Management, ensuring availability through Backup Strategy, proactively responding through Incident Response processes, and finally strengthening the weakest link through User Awareness enhancement. The combination of all these factors determines the survivability of a modern information system.

7.2 Defense-in-Depth Model

7.2.1 Concept of Defense-in-Depth

Defense-in-Depth is a cybersecurity strategy and architecture model designed based on the principle of establishing multiple independent and sequential protection layers. The core philosophy of this model is the acknowledgment that no single security control is perfect. By stacking multiple defense layers, if a malicious actor (malware) or hacker bypasses one layer, the subsequent layers will continue to operate to block, slow down the intrusion process, and protect system assets.

Typical technical defense layers in this model include:

- **Network/Perimeter Layer:** Acts as the outermost defensive boundary, using Firewalls and Intrusion Detection/Prevention Systems (IDS/IPS) to control, filter, and monitor all incoming and outgoing network traffic.

- **Endpoint Layer:** Provides direct protection at user-facing devices (workstations, mobile devices, servers) through Antivirus software and Endpoint Detection and Response (EDR).
- **Application Layer:** Prevents exploitation of software vulnerabilities by applying Secure Coding practices from the development stage and using Web Application Firewalls (WAF).
- **Data Layer:** The most critical core layer, protecting data confidentiality through strong Encryption mechanisms and strict Access Control policies.

7.2.2 Integration of the AAA Access Control Framework

To ensure that defense layers from network to data operate consistently and tightly, organizations need to implement a unified control mechanism called the AAA framework (Authentication, Authorization, Accounting) [3].

The AAA framework governs the entire lifecycle of an entity’s access to the system:

- **Authentication (Authentication - Identity Check):** This is the mandatory starting point of the AAA framework. It acts as a “gatekeeper”, answering the question: “Is this user or device truly the identity they claim to be?”. If this identity verification step is not passed, the subject will be denied access immediately at the outer layer and cannot proceed deeper into application or data layers.
- **Authorization (Authorization - Permissions):** After the system successfully verifies identity in the Authentication step, the Authorization process takes place. This step strictly applies the Principle of Least Privilege, meaning only granting users the minimum permissions necessary to perform their tasks.
- **Accounting (Accounting/Logs):** The final step is to monitor and record all user actions after login. All actions such as opening files, downloading, or modifying data are stored in system logs. This creates non-repudiation and serves as important data for incident investigation.

7.3 Enhancing Access Control and User Authentication

7.3.1 Role of Authentication in Preventing Attacks

User Authentication is the main defensive shield (main shield) against attackers attempting to take over system accounts. In the context of malware distribution campaigns often accompanied by credential theft, a strong authentication mechanism will neutralize the attacker’s ability to perform masquerade attacks on legitimate users, even if they have obtained part of the information.

7.3.2 Weaknesses of Single-Factor Authentication (SFA) and Common Attack Methods

Single-Factor Authentication (SFA), usually based only on passwords (“something you know”), is currently considered very weak and vulnerable. Attackers can easily bypass SFA through the following methods:

- **Brute Force & Dictionary Attacks:** Attackers use automated tools to try thousands of password combinations or use lists of commonly used/leaked passwords. The RockYou data breach (2009) with more than 32 million exposed passwords is evidence of the danger of weak password practices and password reuse.
- **Rainbow Table Attacks:** Exploit insecure password storage systems (hashed passwords without salting) to reverse back to the original passwords, typically the Adobe breach (2013) with 150 million compromised accounts.

7.3.3 Levels of Upgrading Authentication Strategy

To defend effectively, organizations must upgrade authentication systems based on the combination of multiple independent factors:

- **Two-Factor Authentication (2FA) and Multi-Factor Authentication (MFA):** Require users to provide at least one additional verification factor beyond a password, such as “Something you have” (OTP via phone, hardware token) or “Something you are” (Biometrics: fingerprint, face).

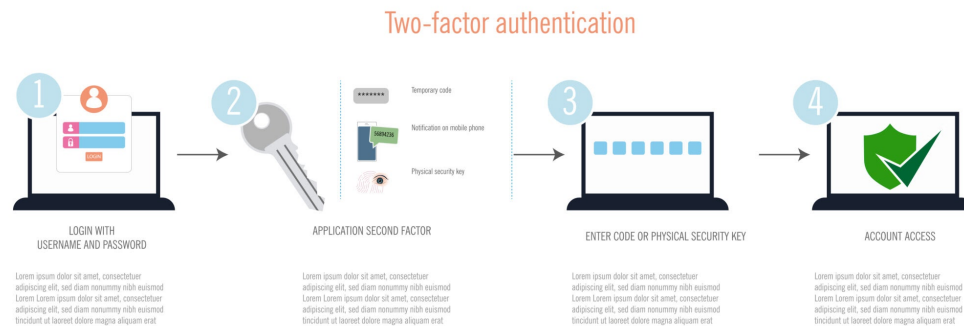


Figure 4: Security reports indicate that implementing MFA can prevent more than 99% of automated account takeover attacks [1].

- **Passwordless Authentication (Passwordless & Passkeys):** This is the most advanced defense technology trend today, based on WebAuthn and FIDO standards. Instead of sharing passwords (shared secrets), Passkeys use cryptographic key pairs stored directly on the device. This method not only optimizes user experience but also completely eliminates risks such as phishing-resistant attacks and credential stuffing [4].

7.3.4 Real-world Case Study: Security Transformation at Google

To cope with the massive scale of online fraud, Google implemented a historic authentication transformation strategy:

- **Phase 1:** Mandatory application of MFA for high-risk accounts (such as administrators) and expansion to general users, combined with push-based authentication to improve usability.

- **Phase 2:** Pioneered global-scale Passkey deployment. This process helped Google significantly reduce operational costs (related to password reset support and account recovery) and protect billions of users from the most sophisticated phishing techniques.

7.4 Patch Management Process and Risk Reduction

7.4.1 Concept and Importance of Patch Management

Patch Management is not simply pressing the “update” button on software; it is a systematic strategic process aimed at fixing security vulnerabilities before they are exploited by attackers [2].

In information security, there exists a concept called the “Vulnerability Window” – this is the period from when a software vulnerability is disclosed until the system is actually patched to fix that vulnerability. Delays, postponement, or ignoring the update process are the root cause that create conditions for malware to spread and cause cyberattacks on a large scale.

7.4.2 Standard Patch Management Process

To ensure the system is not disrupted due to compatibility issues of new updates while still closing vulnerabilities, a professional patch management process in enterprises will go through the following steps:

- **Discovery & Assessment:** Continuously monitor security bulletins to detect new vulnerabilities. Evaluate the severity of vulnerabilities for the current system.
- **Testing:** Never deploy patches directly to the entire production system. Updates must be installed in a simulated environment (Sandbox/Test environment) to ensure they do not conflict with existing business applications.
- **Deployment:** Schedule official updates, prioritizing servers/devices storing important data first.
- **Verification & Monitoring:** Re-check to ensure the patch has been successfully applied and the system operates stably.

7.4.3 Real-world Case Study: WannaCry Ransomware Disaster

The WannaCry ransomware outbreak in May 2017 is the most valuable evidence of weaknesses in patch management processes of organizations worldwide [5].

- **Vulnerability Context:** WannaCry malware was designed to automatically spread through internal networks by exploiting a critical vulnerability in the Windows SMB protocol (identifier CVE-2017-0144, also known as EternalBlue).
- **Deadly Delay:** In fact, Microsoft released a patch for this vulnerability in March 2017. However, many government agencies, hospitals, and large corporations did not perform updates in time.
- **Consequences:** More than 200,000 computers in over 150 countries were infected, all data was encrypted and ransom demanded, paralyzing healthcare and transportation

systems in many countries. If the patch management process had been strictly implemented immediately when Microsoft released the update, this entire disaster could have been completely prevented from the beginning.

7.5 Data Backup Strategy and the 3-2-1 Rule

7.5.1 Importance of Backup in Security

Data backup is considered the “last survival shield” when outer technical defense layers fail before disasters, especially destructive attacks from ransomware. Considering under the core security model CIA Triad (CIA Triad), backup strategy plays a decisive role in protecting Availability, ensuring systems and business services can operate again in the shortest time after incidents.

7.5.2 Gold Standard: The 3-2-1 Backup Rule

To ensure the highest resilience against data loss risks, organizations are recommended to strictly follow the 3-2-1 rule:

- **3 copies of data:** Always maintain at least three copies of important data (including 1 original copy in operation and 2 independent backup copies). Having multiple copies helps minimize the risk of total loss if one copy is corrupted or infected.
- **2 different storage media types:** Store backup copies on at least two different physical technologies or storage systems (for example: NAS and tape). This helps avoid mass hardware failure risks.
- **1 offsite backup:** It is mandatory to have at least one backup located outside the main data center (for example: Cloud or another geographic location). This is the most important protection layer against physical disasters or large-scale malware spread.

7.5.3 Enhanced Defense: Immutable and Air-gapped Backup

In the context of increasingly sophisticated ransomware, they not only encrypt original data but also attempt to delete backup copies connected to the system. Therefore, backup strategies must be upgraded with the following technologies:

- **Immutable Backup:** Data is stored using the WORM (Write Once, Read Many) mechanism, cannot be modified or deleted within a defined period, even by administrators.
- **Air-gap:** Backup copies are completely isolated from internal networks and the Internet, only temporarily connected during backup execution.

7.5.4 Core Benefits and Practical Application

Implementing a proper backup strategy brings essential benefits:

- Fast and accurate data recovery.
- Neutralizing pressure from ransomware attacks.
- Ensuring business continuity.

Real-world example: An enterprise is attacked by ransomware causing all data to be encrypted. Thanks to applying the 3-2-1 rule with backup copies on Cloud, the IT team isolated the system, restored data from a clean backup copy and brought the system back to operation within only a few hours without paying ransom.

7.6 Incident Response Lifecycle

7.6.1 Importance of Incident Response

No matter how well an organization deploys Defense-in-Depth architecture, the risk of intrusion always exists. When an incident occurs (for example: a server is infected with malware, an administrator account is stolen), time is the core factor. A standardized Incident Response (IR) process will help the organization move from a “passive, panicked” state to a “proactive controlled” state, with the goal: early detection of incidents, minimizing impact as much as possible, and restoring systems quickly.

7.6.2 Six Phases of the Incident Response Lifecycle

A complete incident response lifecycle includes six phases:

- **Preparation:** Establish a CSIRT team, build response playbooks, deploy monitoring tools and ensure backup systems are operational.
- **Detection:** Use SIEM or log systems to detect abnormal signs (for example: multiple failed login attempts or sudden increase in encrypted traffic).
- **Containment:** Isolate infected devices, segment the network and lock suspicious accounts to prevent malware from spreading.
- **Eradication:** Remove malware, delete backdoors and patch exploited vulnerabilities.
- **Recovery:** Restore systems from clean backup copies and monitor to ensure no reinfection occurs.
- **Lesson Learned:** Analyze root causes and upgrade the system (for example: transition from SFA to MFA).

7.6.3 Real-world Example (Ransomware Response Scenario)

An employee is tricked into downloading malware from a phishing email:

- The EDR system detects abnormal encryption processes (Detection).
- The computer is isolated from the internal network (Containment).
- The IT team removes malware and cleans the system (Eradication).
- Data is restored from Cloud backup (Recovery).
- The company organizes anti-phishing training and upgrades authentication (Lesson Learned).

7.7 User Awareness and Security Recommendations

7.7.1 Humans: The Weakest Link

In any information system, no matter how perfectly Defense-in-Depth architecture is designed, humans are always considered the “weakest link” in the security chain. Instead of directly attacking technical systems, attackers often use Social Engineering techniques to manipulate users [?].

7.7.2 Common Risky Behaviors

Common mistakes that users often make include:

- **Phishing:** Clicking on fraudulent links leading to credential theft or malware installation.
- **Downloading Malicious Software:** Installing cracked software or from untrusted sources.
- **Weak Passwords:** Using easily guessable passwords or reusing passwords.
- **Ignoring Updates:** Not updating systems, creating vulnerabilities for hackers to exploit.

7.7.3 Recommendations and Solutions

For End Users:

- Use strong passwords and enable MFA.
- Participate in periodic security awareness training.

For Technical Departments:

- Deploy SIEM, EDR for monitoring.
- Apply Network Segmentation.

7.8 Future Trends and Conclusion

7.8.1 Emerging Cybersecurity Threats

Modern attack trends include:

- **AI-powered Malware:** Using AI to create sophisticated malware and phishing.
- **Fileless & Living-off-the-Land:** Attacks without files, using system tools such as PowerShell.
- **Ransomware 3.0 & Supply Chain Attack:** Attacks through supply chains (example SolarWinds).

7.8.2 Overall Conclusion

Cybersecurity threats are increasingly sophisticated and dangerous. Protecting systems cannot rely on a single solution.

To ensure the three core elements of information security:

- Confidentiality
- Integrity
- Availability

Organizations need to:

- Deploy multi-layered defense (Defense-in-Depth)
- Upgrade authentication (MFA, Passkey)
- Build operational and incident response processes
- Enhance user awareness

8 Future Trends in Malicious Software

9 Conclusion

References

- [1] Microsoft Security. One simple action you can take to prevent 99.9 percent of attacks on your accounts. <https://www.microsoft.com/en-us/security/blog/2019/08/15/one-simple-action-you-can-take-to-prevent-99-9-percent-of-attacks/>, 2019.
- [2] David Kim and Michael G. Solomon. *Fundamentals of Information Systems Security*. Jones & Bartlett Learning, Burlington, MA, 4th edition, 2018.
- [3] National Institute of Standards and Technology (NIST). Security and privacy controls for information systems and organizations. <https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final>, 2020. NIST Special Publication 800-53 Rev. 5.
- [4] FIDO Alliance. How passkeys work. <https://fidoalliance.org/passkeys/>, 2023.
- [5] Microsoft. Microsoft security bulletin ms17-010 - critical. <https://learn.microsoft.com/en-us/security-updates/securitybulletins/2017/ms17-010>, 2017.
- [6] National Audit Office (UK). Wannacry ransomware cyber attack. Technical report, National Audit Office, 2017. Public sector cyber incident report.